

GitHub License Scanner

Informe de auditoría técnica, de seguridad y cumplimiento normativo/legal

Fecha del informe: 2026-07-25 03:29 UTC

Rol: Ingeniero de Software Senior + Abogado especialista en tecnología

Alcance: arquitectura, APIs, flujos de datos, seguridad, escalabilidad, privacidad (GDPR/CCPA), propiedad intelectual y contratos

1. Resumen ejecutivo

La aplicación es un escáner de licencias de repositorios GitHub (UI NiceGUI + CLI) que clasifica licencias de repositorio y dependencias, emite un veredicto heurístico sobre venta de software cerrado y sugiere plataformas de deploy. La auditoría identificó **fallos críticos de seguridad y riesgo legal material** (secreto de sesión hardcodeado, historial compartido sin aviso de privacidad suficiente, plantilla de copyright engañosa, veredictos binarios sobre-simplificados). Todos los puntos críticos listados en la sección 3 han sido **corregidos en código** en este mismo cambio, junto con documentación legal (disclaimer, privacy, terms).

2. Arquitectura y flujos de datos

2.1 Componentes

- main.py** — UI NiceGUI (scan / batch / history), i18n ES/EN, export Markdown.
- cli.py** — CLI con códigos de salida 0/1/2 para CI.
- github_api.py** — parseo de URL, metadata y manifests vía api.github.com.
- dependency_scanner.py** — parsers multi-ecosistema (npm, PyPI, Cargo, Go, ...).
- license_analyzer.py** — lookup de registros, clasificación, veredicto, score.
- history_store.py** — persistencia JSON local con retención.
- config.py / rate_limit.py** — configuración por entorno y anti-abuso (nuevo).

2.2 Flujo de datos

Usuario → URL GitHub → parse (owner/repo) → GitHub REST (repo + tree + contents) → parsers de manifests → registros (npm/PyPI/crates/...) → clasificación SPDX-heurística → veredicto / score / replacements / deploy → UI o CLI → opcional history.json. Preferencias de UI viven en cookie firmada (NiceGUI user storage).

2.3 Puntos de fallo (pre-fix)

- Rate limit / 401 / 403 de GitHub sin token (mitigado: mensaje + exit 2 + incomplete).
- Descargas de manifests secuenciales (mitigado: concurrencia acotada).
- Caché de licencias sin TTL (mitigado: TTL + max entries).
- Escritura de history sin atomicidad / lock (mitigado: write atómico + lock de proceso).
- Batch ilimitado y sin rate limit (mitigado: caps + sliding window).
- Ecosistemas Go/Maven/Gradle sin lookup de licencia (riesgo residual: unknown).

3. Hallazgos (antes del remediado)

ID	Severity	Finding
C-01	CRÍTICO	storage_secret hardcodeado en main.py: forja de cookies de sesión en deploys públicos.
C-02	CRÍTICO	Plantilla de copyright atribuía ownership al owner de GitHub (riesgo de uso engañoso / IP).
C-03	ALTO	Historial global en disco sin política de privacidad, borrado UX ni retención por edad.
C-04	ALTO	Sin rate limit ni cap de batch: abuso de GITHUB_TOKEN del servidor y DoS de API.
C-05	ALTO	Veredictos "can_sell_closed / forces_open" presentados de forma binaria sin matizar AGPL/SaaS, linking ni scan incompleto en el modelo de datos.
C-06	MEDIO	Bind por defecto y secreto de desarrollo sin .env.example; riesgo de exposición en LAN.
C-07	MEDIO	Gradle testImplementation no marcado como dev; falsos positivos de copyleft fuerte.
C-08	MEDIO	Ausencia de PRIVACY / TERMS / disclaimer extendido para despliegue multi-usuario (GDPR/CCPA).

C-09	BAJO	verify_app desalineado con compute_verdict de 6+ campos; tests frágiles.
C-10	BAJO	Clasificación de licencias por heurística (no SPDX expression engine completa).

4. Análisis legal y de cumplimiento

4.1 Propiedad intelectual y open source

El Tool clasifica licencias de terceros pero **no sustituye** un análisis de compatibilidad ni due diligence de IP. Especialmente: linking estático/dinámico (GPL), uso en red (AGPL §13, SSPL), dual licensing, permisos adicionales, CLA/DCO y NOTICE de Apache-2.0. La plantilla de copyright anterior era jurídicamente peligrosa porque sugería un titular de derechos sin verificación. Ahora es un template con disclaimer.

4.2 Privacidad (GDPR / CCPA)

Datos típicos: URLs escaneadas, resultados compactos, preferencias de UI. No se piden PII sensibles, pero un deploy multi-usuario sin auth expone historial compartido (posible "dato personal" si el usuario se identifica por repos privados). Mitigaciones: política de privacidad, clear history (derecho de supresión local), retención por edad/máximo de entradas, truncado de verdict_summary en history, bind localhost por defecto. El operador del self-host es el responsable del tratamiento.

4.3 Contratos y disclaimers

Se añadieron TERMS.md, LEGAL_DISCLAIMER.md y refuerzo del disclaimer en UI/export. Se aclara que no hay relación abogado-cliente ni garantía de no infracción. La licencia MIT del Tool no modifica las licencias de los repos escaneados.

4.4 Uso aceptable y GitHub ToS

El usuario debe estar autorizado a acceder a los repos; el rate limit reduce riesgo de violación de límites de API. Solo se contacta api.github.com (sin hosts arbitrarios).

5. Cambios implementados en este remediado

- **config.py** — configuración por entorno (host, port, secrets, límites, retención).
- **rate_limit.py** — sliding window por cliente para scans.
- **.env.example** — plantilla de secretos y límites (sin valores reales).
- **main.py** — storage_secret desde env; host 127.0.0.1; rate limit; cap batch; clear history; páginas /docs/privacy/terms/legal; veredicto incomplete vía scan_complete.
- **github_api.py** — validación owner/repo; rechazo de schemes raros; 429; descargas concurrentes; token desde config.
- **license_analyzer.py** — caché con TTL; notice template legal; AGPL/SSPL network flag; veredicto 7-tupla; scan_complete; EUPL/LGPL variants.
- **history_store.py** — write atómico, lock, prune por edad, no guardar incompletos.
- **models.py** — scan_complete, has_network_copyleft; history truncado.
- **dependency_scanner.py** — Gradle test*/compileOnly como is_dev.
- **report.py / cli.py / i18n.py / README** — disclaimers y UX de cumplimiento.
- **docs/PRIVACY.md, TERMS.md, LEGAL_DISCLAIMER.md** — base normativa.
- **scripts/verify_app.py** — tests alineados con nuevo veredicto y notice.

5.1 Mapa hallazgo → fix

ID	Severity	Finding
C-01	FIXED	GLS_STORAGE_SECRET + warning/ephemeral en bind público
C-02	FIXED	build_copyright_notice como TEMPLATE con warning de ownership
C-03	FIXED	PRIVACY + clear history + max age + truncado
C-04	FIXED	SlidingWindowRateLimiter + MAX_BATCH_URLS
C-05	FIXED	scan_complete, network copyleft, lenguaje de veredicto matizado
C-06	FIXED	Host default 127.0.0.1 + .env.example
C-07	FIXED	Gradle is_dev para configs de test
C-08	FIXED	docs legales + enlaces en UI
C-09	FIXED	verify_app actualizado
C-10	OPEN	Riesgo residual: seguir sin motor SPDX completo

6. Riesgos residuales y mejoras futuras

- Sin autenticación multi-usuario ni historial por usuario (añadir auth + DB si SaaS).
- Sin reverse-proxy TLS / WAF (operador debe poner nginx/Caddy/Cloudflare).
- Lookups incompletos: Go, Maven Central, Gradle; lockfiles no resueltos del todo.
- No modela grafo de linking ni SBOM completo (CycloneDX/SPDX export sería ideal).
- Rate limit in-process no se comparte entre workers; usar Redis en multi-proceso.
- Clasificador de licencias sigue siendo heurístico (integrar package license-expression).
- Tests de integración dependen de red y de GitHub rate limits.

7. Postura de seguridad y escalabilidad

La arquitectura es **single-process / in-memory**, adecuada para uso local o equipo pequeño. Para escala: cola de trabajos, caché compartida, límites en edge, auth, y no compartir GITHUB_TOKEN de alta privilegio. SSRF está mitigado al fijar el host de API a GitHub y validar owner/repo. No se ejecuta código de repos de terceros (solo lectura de manifests de texto), lo cual es positivo desde un punto de vista de seguridad.

8. Conclusión

Tras el remediado, la aplicación presenta una postura sustancialmente más segura y jurídicamente defendible para uso local y auto-hospedado: secretos configurables, límites de abuso, historial con controles de privacidad, disclaimers y documentos normativos, y veredictos que no simulan ser dictámenes legales. El riesgo residual principal es la **sobreconfianza del usuario** en heurísticas automáticas y la incompleción de metadatos de algunos ecosistemas. Se recomienda mantener el disclaimer visible y no comercializar el output como asesoría legal sin revisión humana cualificada.

Documento generado automáticamente como parte del remediado de código. No constituye asesoramiento jurídico vinculante.